

Сегментация сети, которая реально работает: как остановить латеральное движение Red Team и спасти бизнес

 redsec.by/article/segmentaciya-seti-kotoraya-realno-rabotaet-kak-ostanovit-lateralnoe-dvizhenie-red-team-i-spasti-biznes

Red Teams | 29 декабря 2025



В 2025 году ландшафт киберугроз окончательно перешел в фазу «сверхзвуковых скоростей». Если раньше у отдела ИБ были дни или недели на обнаружение злоумышленника в сети, то сегодня счет идет на минуты. Современные вымогатели, такие как LockBit 4.0, способны зашифровать всю инфраструктуру предприятия менее чем за 20 минут. Согласно актуальной статистике, среднее время, необходимое атакующему для начала горизонтального перемещения (lateral movement) после первичного взлома, составляет всего 48 минут.

Почему же большинство компаний до сих пор оказываются бессильными? Ответ кроется в архитектурном наследии — «плоской» сети. Как профессионал в области кибербезопасности, я могу с уверенностью заявить: плоская сеть — это самый страшный кошмар CISO.

В этой статье мы разберем, почему сегментация — это не «желательная мера», а фундамент выживания, изучим реальные кейсы с многомиллионными потерями и перейдем к конкретной технической реализации на оборудовании Cisco и FortiGate.

Почему «плоская» сеть — это подарок для хакера

Представьте себе современный бизнес-центр, где нет ни одной двери, ни одной перегородки и ни одного пропуска. Каждый, кто зашел с улицы через центральный вход, получает беспрепятственный доступ к серверной, кабинету генерального директора и архивам бухгалтерии. Абсурдно? В мире сетевой архитектуры это реальность тысяч компаний.

Плоская сеть подразумевает, что все устройства — от принтера в приемной до контроллера домена — находятся в одном широковещательном домене (VLAN). Если злоумышленник скомпрометировал ноутбук рядового сотрудника, он автоматически получает «билет» на исследование всей сети.

Сравнение времени атаки: плоская сеть vs. сегментированная сеть

Статистика неумолима. В плоской сети путь от «первичного заражения» до «полного шифрования» занимает в среднем около часа. В сети с грамотной сегментацией и настроенными правилами фильтрации трафика (ACL) этот процесс либо останавливается на этапе разведки, либо замедляется в десятки раз, давая команде SOC (Security Operations Center) драгоценное время на реагирование.

- **Плоская сеть:** 0–45 мин до полного захвата Domain Admin.
- **Сегментированная сеть:** Атака блокируется на уровне попытки сканирования соседних подсетей.

Кейс из практики Orange Cyberdefense: «Миллионная плоская сеть»

Чтобы не быть голословным, разберем реальный случай из практики французских коллег, который стал классическим примером того, как отсутствие сегментации уничтожает бизнес за час.

Сценарий атаки: Как потеря €1,5 млн могла быть предотвращена

При аудите одной крупной логистической компании была выявлена катастрофическая архитектура. Сеть была абсолютно плоской. Более того, на всех узлах использовался одинаковый пароль локального администратора.

Хронология катастрофы:

- **0 мин:** Бухгалтер открывает вложение в фишинговом письме. Активируется макрос, загружающий Emotet.
- **5 мин:** Антивирус сигнализирует о подозрительной активности, но из-за специфики обфускации не может полностью заблокировать процесс в памяти.

- **15 мин:** Атакующий извлекает хеши паролей из памяти. Благодаря одинаковому паролю локального админа, он получает доступ ко всем рабочим станциям в той же подсети.
- **30 мин:** Запуск инструмента **BloodHound**. Это ПО за несколько минут автоматически строит карту кратчайших путей к правам администратора домена.
- **45 мин:** Обнаружен контроллер домена (DC). Прямая видимость по SMB (порт 445) позволяет провести атаку типа Pass-the-Hash.
- **60 мин:** С помощью PsExec по всей сети распространяется скрипт, запускающий шифровальщик Ryuk на 4000+ машинах одновременно.

Итог: Бизнес парализован.

Стоимость: €0,5 млн — выкуп, €0,5 млн — восстановление, €0,5 млн — юридические издержки и репутационные потери.

Вывод эксперта: Все это предотвращается внедрением VLAN и запретом SMB-трафика между пользовательским сегментом и серверами. Всего несколько часов работы сетевого инженера сэкономили бы €1,5 млн.

Три аналогии для понимания сути сегментации

Если вы объясняете важность сегментации руководству, забудьте про порты и протоколы. Используйте эти три образа:

- **Здание с отсеками:** Плоская сеть — это ангар. Сегментированная сеть — это банк с бронированными дверями между хранилищем, кассой и залом ожидания.
- **Подводная лодка:** Если в одном отсеке пробоина, переборки закрываются герметично, и лодка продолжает путь. В плоской сети один свищ топит все судно.
- **Иммунная система:** Сегментация — это лимфоузлы, которые локализуют инфекцию, не давая ей поразить сердце и мозг (ваши базы данных и контроллеры домена).

Практическое руководство: Как настроить VLAN и ACL

Перейдем к технической части. Мы будем строить архитектуру на базе межсетевого экрана FortiGate (Gateway/Firewall) и коммутаторов с поддержкой 802.1Q.

Шаг 1: Планирование архитектуры (Логическое деление)

Для типичного предприятия среднего размера минимально необходимый набор VLAN выглядит так:

- **VLAN 10 (Users):** Рабочие станции сотрудников, ноутбуки. Самый рискованный сегмент.
- **VLAN 20 (Servers):** Базы данных, файл-серверы, веб-сервисы.

- **VLAN 30 (Management):** Контроллеры домена, системы мониторинга, консоли управления ИТ. Доступ сюда должен быть максимально ограничен.
- **VLAN 40 (Guest Wi-Fi):** Гостевой доступ. Полная изоляция от внутренних ресурсов.

Шаг 2: Конфигурация VLAN на коммутаторе (Cisco IOS)

Создаем «магистраль» (Trunk), по которой трафик будет идти к файрволу, где и будут приниматься решения о фильтрации.

```
interface GigabitEthernet0/0
no ip address
no shutdown

interface GigabitEthernet0/0.10
encapsulation dot1q 10
ip address 10.1.10.1 255.255.255.0
description "Users VLAN - Untrusted Segment"

interface GigabitEthernet0/0.20
encapsulation dot1q 20
ip address 10.1.20.1 255.255.255.0
description "Servers VLAN - Trusted Assets"

interface GigabitEthernet0/0.30
encapsulation dot1q 30
ip address 10.1.30.1 255.255.255.0
description "Management VLAN - Critical Infrastructure"

interface GigabitEthernet0/0.40
encapsulation dot1q 40
ip address 10.1.40.1 255.255.255.0
description "Guest WiFi - Isolated Internet Only"
```

Шаг 3: Настройка правил фильтрации (ACL)

Это сердце системы. Мы используем принцип **Least Privilege** (наименьших привилегий).

Правило №1: Смерть латеральному движению (Блокировка SMB)

SMB (порт 445) — основной транспорт для шифровальщиков и утилит типа PsExec. Обычному пользователю не нужно ходить по SMB на серверы напрямую, если это не выделенный файл-сервер.

Конфигурация FortiGate CLI:

```
config firewall policy
edit 1
set name "DENY_SMB_Users_to_Servers"
```

```
set srcintf "port1_vlan10"
set dstintf "port2_vlan20"
set srcaddr "Users_Subnet"
set dstaddr "Servers_Subnet"
set service "SMB"
set action deny
set schedule "always"
set logtraffic all
next
end
```

Правило №2: Блокировка PowerShell Remoting (WinRM)

Red Team обожают порты 5985/5986 для скрытного управления системами.

```
config firewall policy
  edit 2
  set name "DENY_WinRM_Users_to_Servers"
  set srcintf "port1_vlan10"
  set dstintf "port2_vlan20"
  set srcaddr "Users_Subnet"
  set dstaddr "Servers_Subnet"
  set service "WinRM"
  set action deny
  next
end
```

Правило №3: Разрешение необходимых сервисов (DNS/LDAP)

Чтобы сеть работала, мы должны разрешить базовые запросы к контроллеру домена (Management VLAN).

```
config firewall policy
  edit 3
  set name "ALLOW_DNS_LDAP_to_DC"
  set srcintf "port1_vlan10"
  set dstintf "port3_vlan30"
  set srcaddr "Users_Subnet"
  set dstaddr "DC_IPs"
  set service "DNS" "LDAP"
  set action accept
  next
end
```

Правило №4: Изоляция Guest Wi-Fi

Гости не должны видеть внутреннюю сеть вообще. Только интернет.

```
config firewall policy
  edit 6
  set name "DENY_Guest_to_Internal"
  set srcintf "port4_vlan40"
```

```
set dstintf "any"
set srcaddr "Guest_Subnet"
set dstaddr "Internal_Networks"
set action deny
next
end
```

Шаг 4: Золотое правило — Default Deny All

Самая частая ошибка — оставить в конце списка правил неявное разрешение. В профессиональной безопасности последним правилом всегда идет «Запретить все остальное».

```
config firewall policy
edit 99
set name "DEFAULT_DENY_ALL"
set srcintf "any"
set dstintf "any"
set srcaddr "all"
set dstaddr "all"
set action deny
set schedule "always"
next
end
```

На Linux-серверах (iptables) это выглядит аналогично:

```
# Устанавливаем политики по умолчанию
iptables -P INPUT DROP
iptables -P FORWARD DROP
iptables -P OUTPUT ACCEPT

# Разрешаем уже установленные соединения
iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT

# Разрешаем SSH для админов
iptables -A INPUT -p tcp -s 10.1.30.0/24 --dport 22 -j ACCEPT
```

Как это останавливает атаку в реальности?

Давайте вернемся к нашему сценарию с Emotet, но уже в сегментированной сети.

- **Заражение ноутбука (10.1.10.45).**
- **Попытка латерального движения:** Вредонос пытается подключиться к контроллеру домена по SMB (порт 445).
- **Срабатывание FortiGate:** Пакет попадает на фаервол. Система видит правило DENY_SMB_Users_to_Servers. Пакет отбрасывается.
- **Результат для атакующего:** "Access Denied" или "Network path not found".

- **Результат для ИБ:** В логах SIEM-системы (например, Wazuh или ELK) мгновенно появляется аномалия: «*Заблокировано 50 попыток соединения по порту 445 от одного хоста из Users VLAN*».

Атака остановлена на взлете. Злоумышленник изолирован в своей «песочнице» (VLAN 10), не имея возможности добраться до критических данных.

Видимость и мониторинг: Логи — ваши глаза

Правила без логирования бесполезны. Профессиональный подход подразумевает, что каждое заблокированное соединение должно генерировать событие в системе мониторинга.

Инструменты разведки, такие как **Nmap** или **Zmap**, при попытке сканирования сегментированной сети вызывают «шторм» заблокированных пакетов. Современные системы NDR (Network Detection and Response) анализируют эти паттерны и автоматически изолируют порт нарушителя на уровне коммутатора.

ROI: Почему сегментация — это выгодно

Для бизнеса безопасность — это всегда вопрос цифр.

- **Убытки от взлома:** от \$1 млн (средний чек по миру в 2024–2025 гг.).
- **Затраты на внедрение:** Около 100–160 часов работы высококвалифицированных инженеров. Даже при высокой ставке это несопоставимо с возможными потерями.

Экономическая эффективность (ROI) сегментации составляет тысячи процентов, так как она предотвращает самый дорогой вид киберугроз — полную остановку бизнес-процессов.

Чек-лист для внедрения сегментации

- **Аудит (1-2 недели):** Поймите, кто и с кем общается в вашей сети. Используйте NetFlow для визуализации трафика.
- **Проектирование:** Разбейте сеть на VLAN. Не плодите их слишком много, начните с 4–5 основных.
- **Пилот:** Внедрите правила сначала в режиме мониторинга (Log Only), чтобы убедиться, что вы не заблокируете работу бухгалтерии или легитимных сервисов.
- **Enforcement:** Переключите правила в режим Deny.
- **Автоматизация:** Интегрируйте логи фаервола с вашей SIEM-системой.

Оценка предоставленных изображений

Ваши изображения крайне полезны и **обязательны** для добавления в статью. Они наглядно иллюстрируют сложные концепции:

- **Таблица правил:** Помогает быстро понять логику ACL. Разместите её в Главе 4.
- **Схема сети (FortiGate):** Идеально подходит для визуализации Шага 1.
- **График атаки (Timeline):** Отлично дополняет вступление и Главу 2, создавая эмоциональный и рациональный акцент на времени.

Сегментация сети — это не серебряная пуля, но это самая надежная броня, которую вы можете надеть на свою инфраструктуру. В мире, где периметр давно размыт, а атаки автоматизированы, только жесткая изоляция сегментов и принцип нулевого доверия позволяют сохранить контроль над ситуацией. Начните сегодня, чтобы завтра не оказаться в хронике очередного громкого взлома.